

# Challenge Lab Incognito Travel by Hack Smarter

## Objective

Incognito Travel is rolling out a new authentication process for their flagship travel application. Before deploying to production, they have contracted Hack Smarter to rigorously test the new authentication flow. The target application leverages Amazon Cognito to handle its identity and access management.

Taking over the admin account is the goal.

## Initial access

The client has provided you with the URL but no other information for initial access.

After whitelisting your IP and launching the scenario, you will receive a "starting website". This is the in-scope website for the engagement, and the only information you need.

### Command Output (Terraform/CloudGoat)

```
Using default profile "default" from config.yml...

[cloudgoat] terraform init completed with no error code.

[cloudgoat] terraform plan completed with no error code.

[cloudgoat] terraform apply completed with no error code.

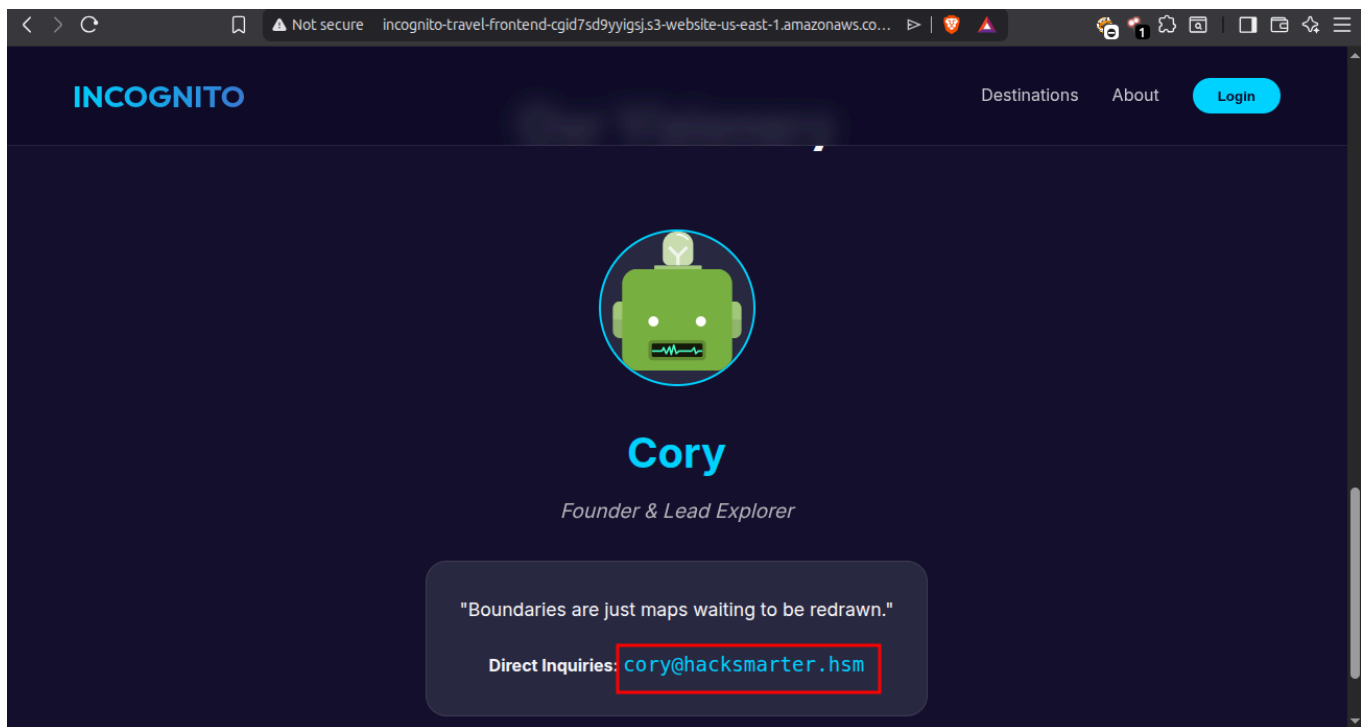
[cloudgoat] terraform output completed with no error code.
Starting_Website = http://incognito-travel-frontend-cgid7sd9yyigsj.s3-website-us-east-1.amazonaws.com
cloudgoat_output_api_url = https://xdusfkeowg.execute-api.us-east-1.amazonaws.com

[cloudgoat] Output file written to:

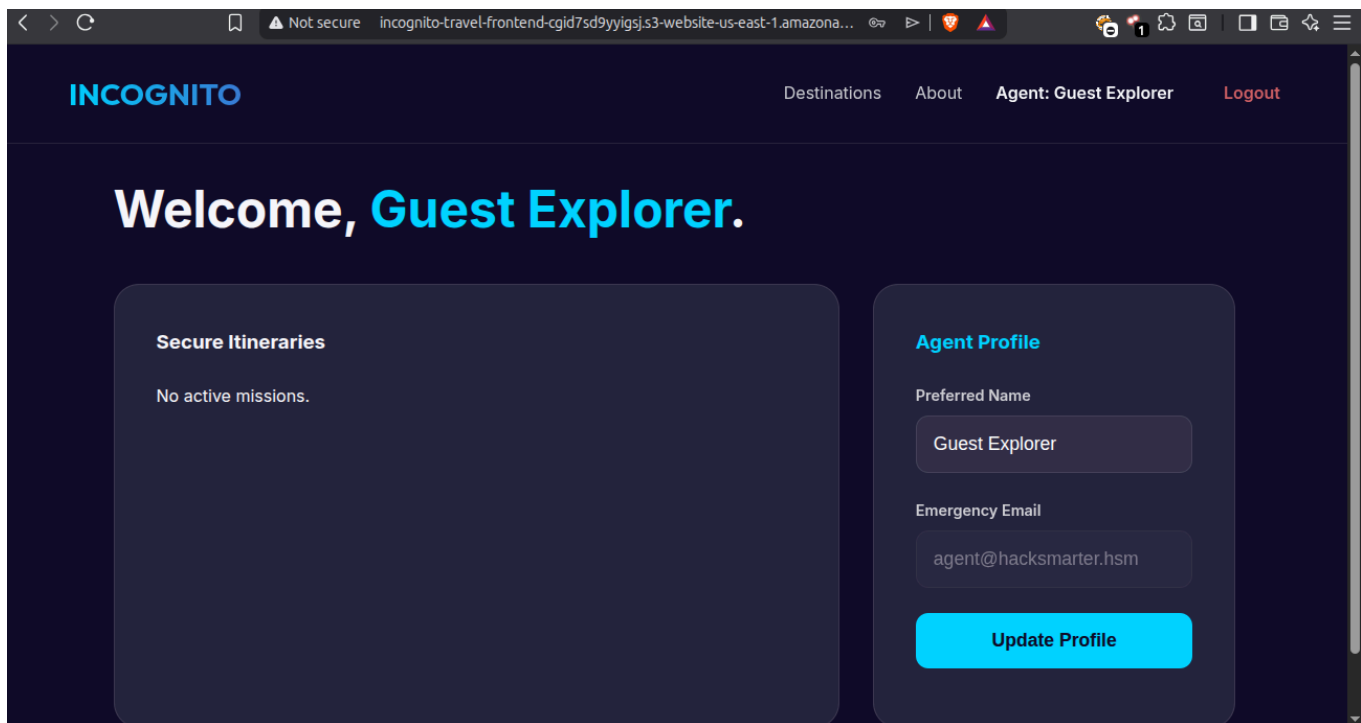
    /home/ubuntu/aws-labs-deploy/myenv/lib/python3.10/site-
packages/cloudgoat/incognito_travel_cgid7sd9yyigsj/start.txt
```

## Enumeration & Initial access

We explore the website and discover a contact email that is located in: about section, It appears as a potential target for privilege escalation.



We are able to register an account and login as `agent@hacksmarter.hsm:Password`.



By examining the source code we can notice that Cognito AWS is what's implemented which is a fully managed identity and access management service from AWS that enables developers to add **user sign-up, sign-in, and access control** to web and mobile applications quickly and securely. In this case using the `userPoolId` and `clientId`

Not secure incognito-travel-frontend-cgid7sd9yyigsj.s3-website-us-east-1.amazona...

Elements Console Sources Network Performance Memory Application Security Lighthouse

```
<button class="btn-submit" id="action-btn" onclick="handleAuth()">Login</button>
<p style="text-align: center; margin-top: 1.5rem; font-size: 0.9rem;">
  <a href="#" onclick="toggleAuth()" id="toggle-link" style="color: var(--highlight); font-weight: 600; text-decoration: none;">Request Access</a>
</p>
<div id="message" style="margin-top: 1.5rem; text-align: center; font-weight: 600; color: var(--success);">Access Granted.</div>
</div>
</div>
<script>
const COGNITO_CONFIG = { userPoolId: 'us-east-1_DK6YeIXZd', clientId: '55bk7btfipde4jaiftn0vipml1' };
const API_URL = 'https://xdusfkeowg.execute-api.us-east-1.amazonaws.com';
let isLogin = true;

function openModal() { document.getElementById('login-modal').style.display = 'flex'; }
function closeModal() { document.getElementById('login-modal').style.display = 'none'; }
function logout() { localStorage.clear(); location.reload(); }

function toggleAuth() {
  isLogin = !isLogin;
  document.getElementById('modal-title').innerText = isLogin ? 'Authenticate' : 'Request Access';
  document.getElementById('action-btn').innerText = isLogin ? 'Login' : 'Submit Request';
  document.getElementById('toggle-link').innerText = isLogin ? 'Request Access' : 'Return to Authentication';
  document.getElementById('message').innerText = '';
}
```

html body script (text)

In the local storage, there is two JWT tokens: id\_token and token

Not secure incognito-travel-frontend-cgid7sd9yyigsj.s3-website-us-east-1.amazona...

Application

Manifest

Service workers

Storage

Local storage

http://incognito-trav...

Session storage

http://incognito-trav...

Extension storage

IndexedDB

Cookies

http://incognito-trav...

Cache storage

Storage buckets

Background services

Back/forward cache

Bounce tracking mitiga...

Filter

http://incognito-travel-frontend-cgid7sd9yyigsj.s3-website-us-east-1.amazonaws.com

| Key      | Value                                                           |
|----------|-----------------------------------------------------------------|
| id_token | eyJraWQiOiJlEQkVjZmFVK3VhZjFpRmVieFVMc2tNQjVhMlUydDJUQ2NLdnZ... |
| token    | eyJraWQiOiIyWUVVC2M4SUpnang2eHg5VmJLTkhMY0lSYWpXckthWnVfVL...   |

No value selected

Select a value to preview

What's new in DevTools 148

See all new features

Agentic extensions debugging

```
eyJraWQib0iJEQkZjVzMVFK3VkJzFpRmVjeFVMc2t2NqjVklUydzJDU0Zn
LdnZVU1dqbWlPSIsImF5ZyI6IlTmJfU2In0.eyJzdWUiOiI4NGQ4Mj
QwOC0wMGYxLTcwMGU0MTM2OC1hODVlMmM3ODY3NDQlClJpc3MiOiJod
HRwc3ovL2NvZ25pdG8taWRwLnVzLWVhc3Q0MS5hbWV6b25hd3MuY29t
L3VzLWVhc3Q0MTV9ESZ3Z3UyYmQlClJjb2duaXRvOnVzZXJwY1lIjo
iODRkODl0MDgtMDBmMS03MDBLLTEzNjgtYTYyYjFjNzg2Nz00Iiwib3
JpZ2ZlX2p0aSI6IjI3NjY0YyJhL2dmNTMtNGQyZS05MTQzL2LTwNjVlY
zM5MjM2MSIsImF1ZCI6IjU1Yms3YnRmaXBkZTRqYWlmdG0wdmLWbWxp
IiwiaXZlbnRfaWQiOiJmOWM3MmIwYi00YVViLTQ2Y2YtODY3ZC00Mjk
wYmQ5NjMlZjEiLCJ0b2t1b2l9lc2UiOiJpZCIiSImF1dGhfdGltZSI6MT
c30tK4NDkzMywiZXhwIjoxNzc3ODU0MTMzLCJpYXQiOi0E3Nzk5ODQ5M
zMsImp0aSI6Ijc4ZjZlZGZyY1ZjY1NDI3Y105ZWZlLTQzNjY2Nzg1
OTRlYSIsImVtYWlsIjoiYVd1bnRaaGFja3NtYXJ0ZXUuaHNTIn0.KvT
N8t3Vv_-NyXL0jFruS1dBKQfgPeg3k6B0Knk-
33uHERftPwCj66Zaply6CLUELb-
kSPFAwqkzzcv1DVQ0SdVzLT_vn2vHRvNgSSGWPisxkJTL_vLCbyAKDP
-
iS9cmkHYgsiF3wXiKZFttWxLCp0TsIPfLM06j8ks4nSLfHNabTpoNM
72ICv_qzaE97WS2EQaYAG5np_u9ZjmSR4JRxybBAXpF5HUsE3jY27or
mPaWuI3L390huoLrN_mzIfcgAV_0gTkeW_gdEEO_jq9i2e0yU1Iyi0m
CzyiCQwCf69vfdX3DbVfEPFnhAdoLf0-6Fz6BcVJ2I7ZR21Fm460ngj
```

After using the token, we can collect user information from Cognito with AWS cli.

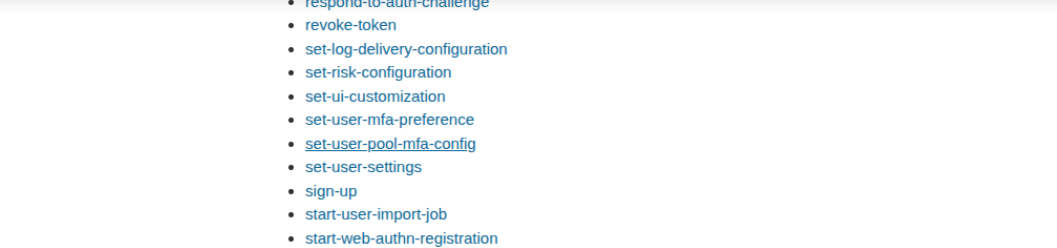
```
wizard-zero@Wiz-Zero:~$ aws cognito-idp get-user --region us-east-1 --access-token eyJraWQioIiYWUVCVZM4SUpnang2eHg5VmJLTxHMY0L5YwPxCkctHWnVfVLhoSLhsTXNjPSIsImFsZyI6IlJTMjU2In0.eyJzdWIiOiIANGQMjQwO0cwMGYxLTcwMGUtMTM2OC1hODViMM3ODY3NDQiLCJpc3MiOiJodHRwciovL2NyZ25pdG8taWRwLnVzLWVhc3QtMS5hbWFi6b25hd3MuY29tL3VzZWVhc3QtMV9ESzZZZUYWmQilCjBjbGlbnRfaWQioIiINWJRn2J0ZmlwZGU0amFpZnRtMHZpcG1saSIsIm9yaWdpbl9qdGkiOiJmZTQ2MThjZS1lNmM1LTQ1YVYTYTU1Zi05NDA4NmU2YWZiYTIIiLCJldmVudF9pZCI6IjUyZTlmNTg1LTl0MWQtnGE5ZC04MDhhLWIWycjZTEwNmI5MCIsInRva2VuX3VzSI6ImFjY2VzcysIsInNjb3BlIjoieYXdzLmNvZ25pdG8uc2lnbm1uLnVzZXIueYWRtaW4iLCJhdXRoX3RpblUiOjE3Nzk5ODkwMjIsImV4cCI6MTc3OTk5MjYyMiwiawWF0iJoxNzc5OTg5MDIyLCJqdGkiOiJmOTllZmIzNi02NjM5LTRjZmQtdOkxOS05OGGYDzhkhNDBLMjM1LCJlc2VybmFtZSI6Ijg0ZDZgdnyNDA4LTAwZjEtZTNhZSw0xMzY4LWE4NWIXyzc4Njc0NCJ9.KZQ-lbGHdYUA_u-sCx5_CaikUF1KMdmYVQME9L7K0z_cFHveR9Yt2i2v8UxrufNXrpT_iug76wnZXZ1mc0_jGvrkJTndktDKkvGVyi7faEYNVEDrnmSm6ISGCEYe9-QfaQPME_XT4Nw15Fr1VDZ0nlp3aqrZULVeT20CP8GUKaCK77c12DNxq29XVHNEEvp_gL-Rsu9qw_IARHVOL3z6nLaBCargevXptAzzr3kTv123BVUU4uaEOUnG_XIjlCx-0TXusc1aDBSrSPVA8c2UBVSaz0uV84aWMBIHtp-kBMMy7Y3Plva-pFrK8NZi_kFPazX8Sqihpw07LDJkABbcE_Q
```

```
{  
  "Username": "84d82408-00f1-700e-1368-a85b1c786744",  
  "UserAttributes": [  
    {  
      "Name": "email",  
      "Value": "agent@hacksmarter.hsm"  
    },  
    {  
      "Name": "sub",  
      "Value": "84d82408-00f1-700e-1368-a85b1c786744"  
    }  
  ]  
}
```

```
wizard-zero@Wiz-Zero:~$
```

<https://docs.aws.amazon.com/cli/latest/reference/cognito-idp/>

Since we already have a low privilege user access, attempting to test the permissions and



The screenshot shows the AWS CLI Command Reference page for Cognito IDP. The page has a navigation bar with links to Home, User Guide, Forum, and GitHub. A 'Star' button shows 16,997 stars. The main content area lists various CLI commands. A red rectangular box highlights a group of commands starting with 'update-user-pool'.

**AWS CLI Command Reference** Home User Guide Forum GitHub

Star 16,997

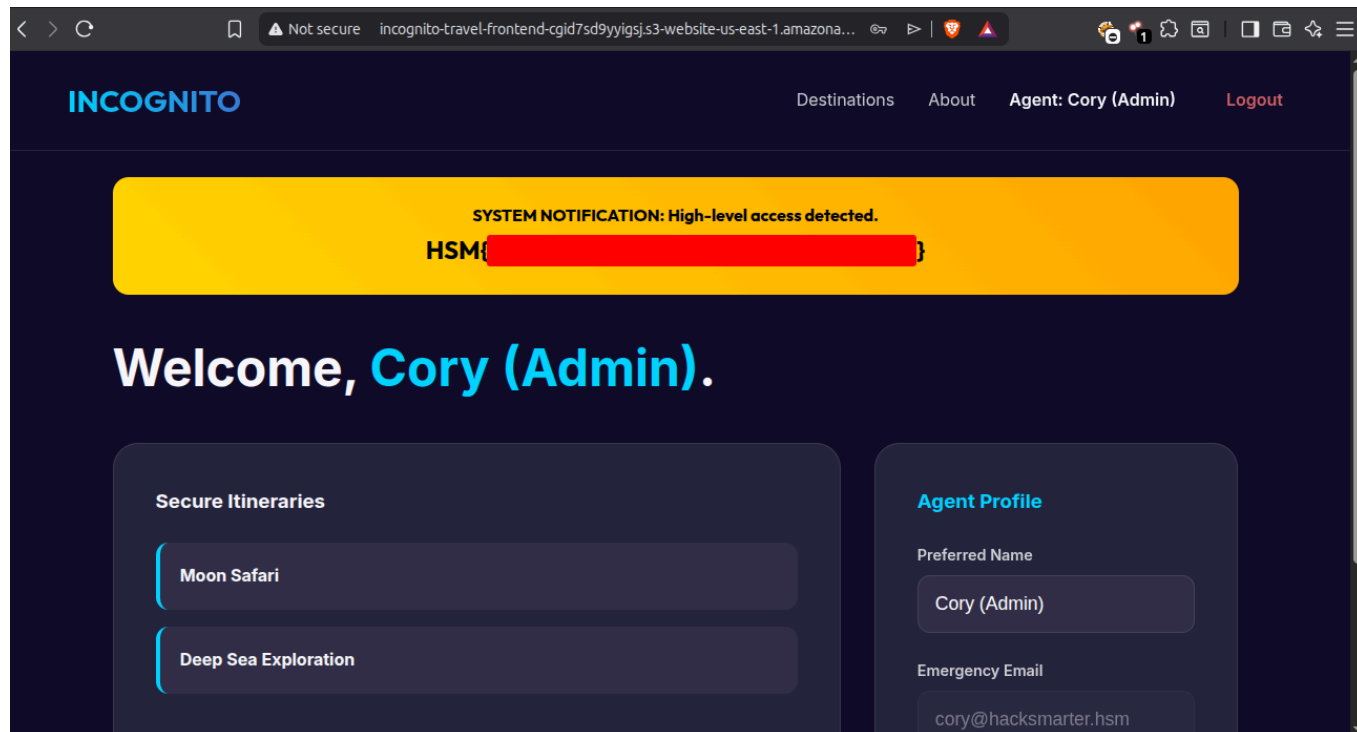
- [respond-to-auth-challenge](#)
- [revoke-token](#)
- [set-log-delivery-configuration](#)
- [set-risk-configuration](#)
- [set-ui-customization](#)
- [set-user-mfa-preference](#)
- [set-user-pool-mfa-config](#)
- [set-user-settings](#)
- [sign-up](#)
- [start-user-import-job](#)
- [start-web-authn-registration](#)
- [stop-user-import-job](#)
- [tag-resource](#)
- [untag-resource](#)
- [update-auth-event-feedback](#)
- [update-device-status](#)
- [update-group](#)
- [update-identity-provider](#)
- [update-managed-login-branding](#)
- [update-resource-server](#)
- [update-terms](#)
- [update-user-attributes](#)
- [update-user-pool](#)
- [update-user-pool-client](#)
- [update-user-pool-domain](#)
- [verify-software-token](#)
- [verify-user-attribute](#)

docs.aws.amazon.com/cli/.../set-user-pool-mfa-config.html

[illegible]

After trying to login again using cory email along with agent password we registered with, it

results in successful login and flag retrieval.



## Summary

Web enumeration resulted in discovering the target user cory and that AWS Cognito is used. After completing registration as a low privileged user and using the assigned token, we explore possible misconfigurations to discover that email change is possible. We then exploit this by updating our account's email and a case insensitive letter of the target user cory as `Cory@hacksmarter.hsm`. Because the application does not properly verify the email for user identification, along with Cognito's default check for an authenticated user to be able to modify their own email parameters, the case insensitive email matching allows us to assume the victim's identity. Logging in with the modified email grants us authenticated access as the victim account and completing the objective to acquire access as admin.